

**VIETNAM NATIONAL UNIVERSITY – HO CHI MINH CITY
INTERNATIONAL UNIVERSITY
SCHOOL OF COMPUTER SCIENCE AND ENGINEERING**



**WEB APPLICATIONS DEVELOPMENT
IT093IU
LAB 9**

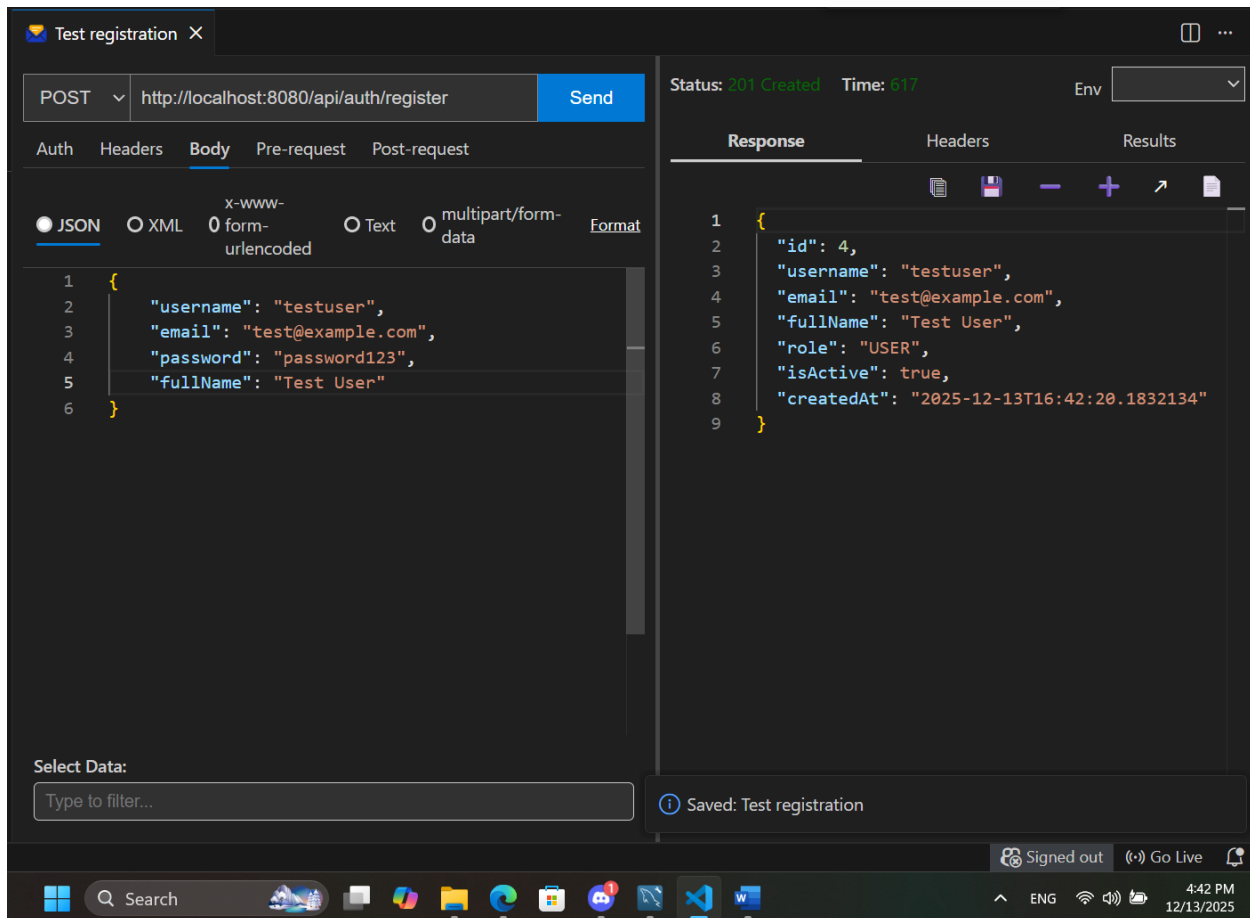
Member List:

- Huỳnh Ngọc Bảo Long – ITITWE23023

Instructor: MSc. Nguyễn Trung Nghĩa

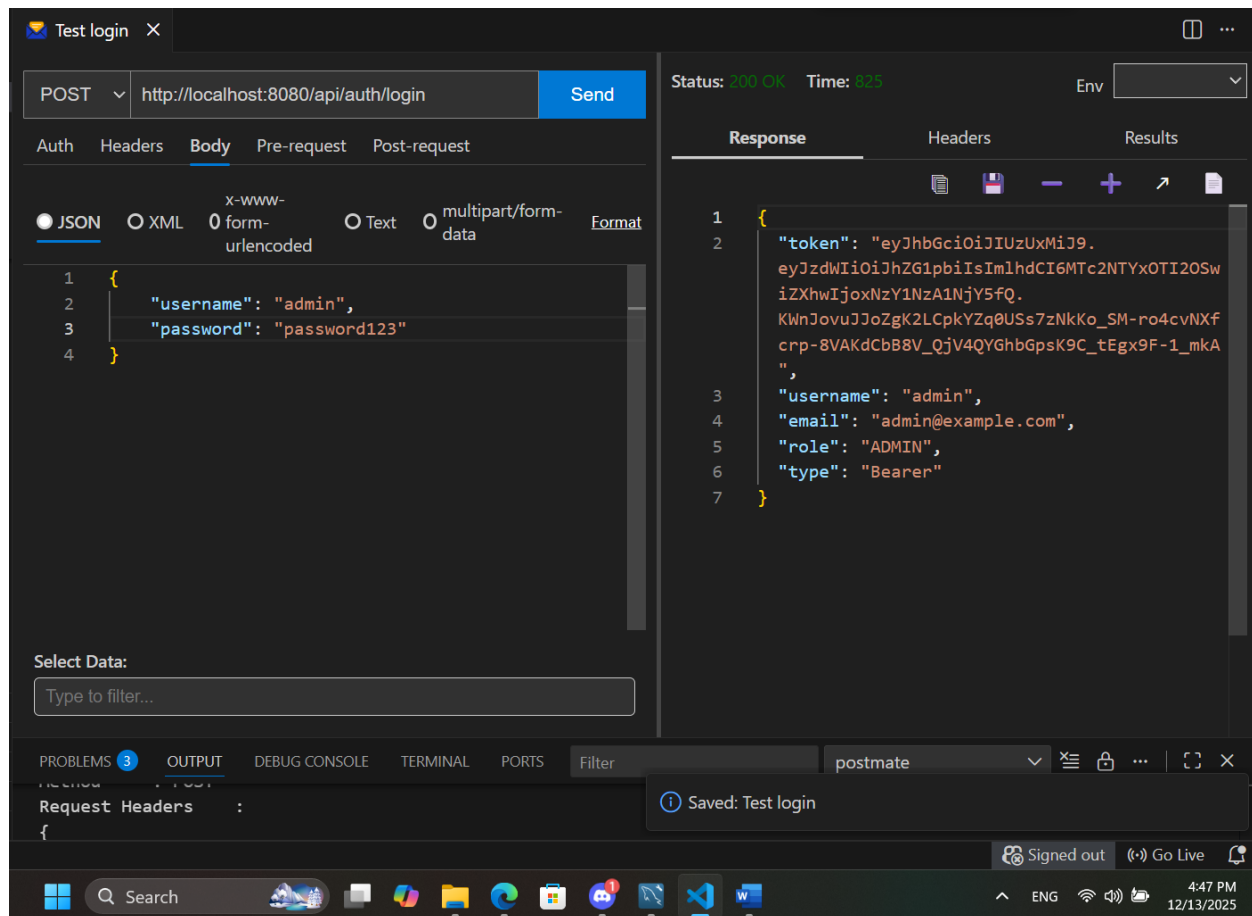
1. REGISTRATION

- Client → POST /api/auth/register {username, email, password}
- Server → Hash password with BCrypt
- Server → Save user to database
- Server → Return: 201 Created



2. LOGIN

- Client → POST /api/auth/login {username, password}
- Server → Verify username exists
- Server → Compare password with hashed password
- Server → Generate JWT token with username, role, expiry
- Server → Return: {token: "eyJhbG...", username, email, role}
- Client → Store token in localStorage



3. ACCESSING PROTECTED ENDPOINT

- Client → GET /api/customers

Header: Authorization: Bearer eyJhbG...

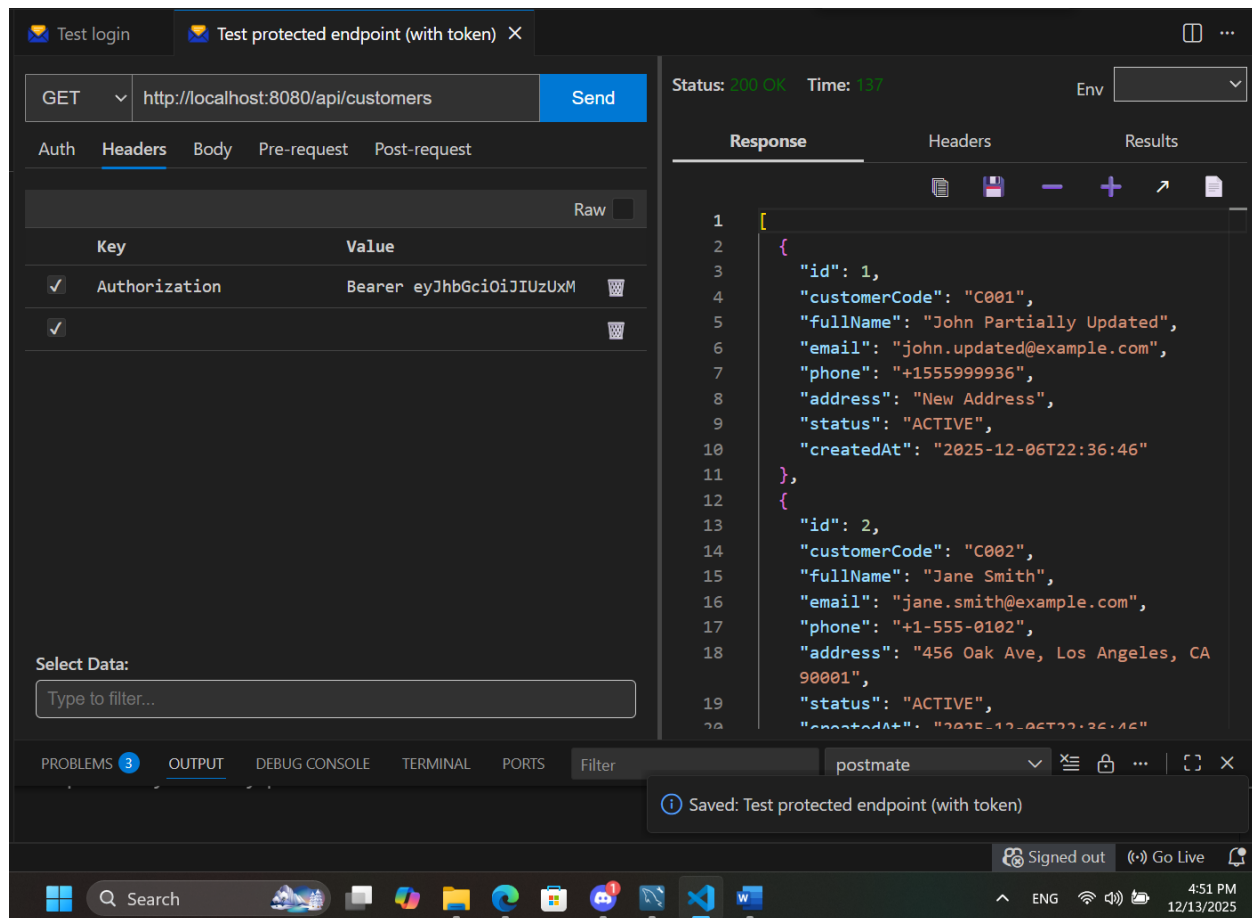
- Server → JwtAuthenticationFilter intercepts request
- Server → Extract token from Authorization header
- Server → Validate token (signature, expiry)
- Server → Extract username from token
- Server → Load user details from database
- Server → Set authentication in SecurityContext
- Server → Process request
- Server → Return response
 - Without token

The screenshot shows the Postman application interface. The top tab is titled "Test protected endpoint (without token)". The request is a GET to `http://localhost:8080/api/customers`. The "Send" button is highlighted. The "Headers" tab is selected in the left sidebar. The response pane on the right shows a 401 Unauthorized status with the following JSON body:

```
1 {
2   "path": "/api/customers",
3   "error": "Unauthorized",
4   "message": "Authentication required.
5     Please provide valid JWT token.",
6   "timestamp": "2025-12-13T16:49:18.
7     905921800",
8   "status": 401
9 }
```

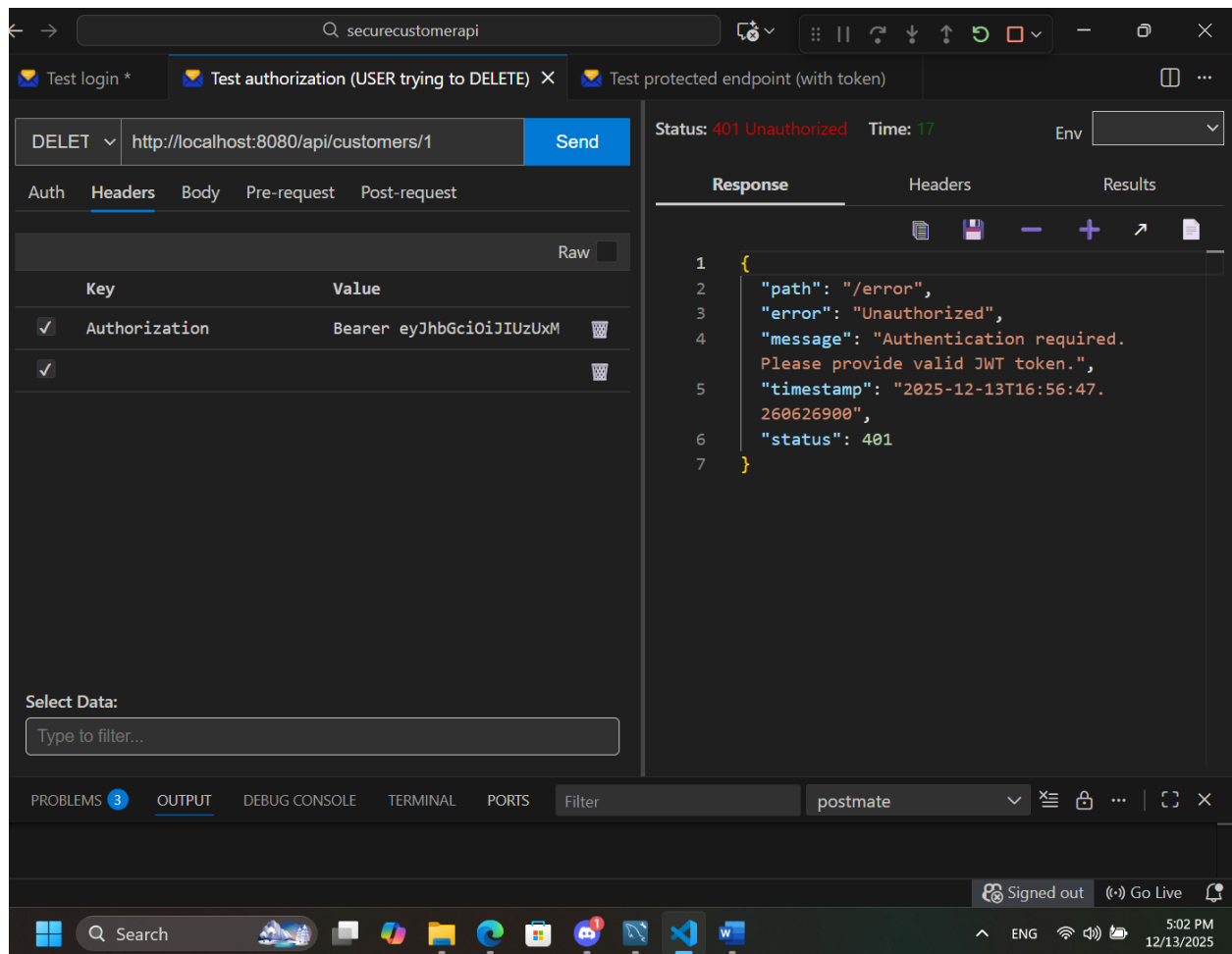
The bottom status bar shows "Saved: Test protected endpoint (without token)". The Windows taskbar at the bottom indicates the time is 4:49 PM on 12/13/2025.

- With token

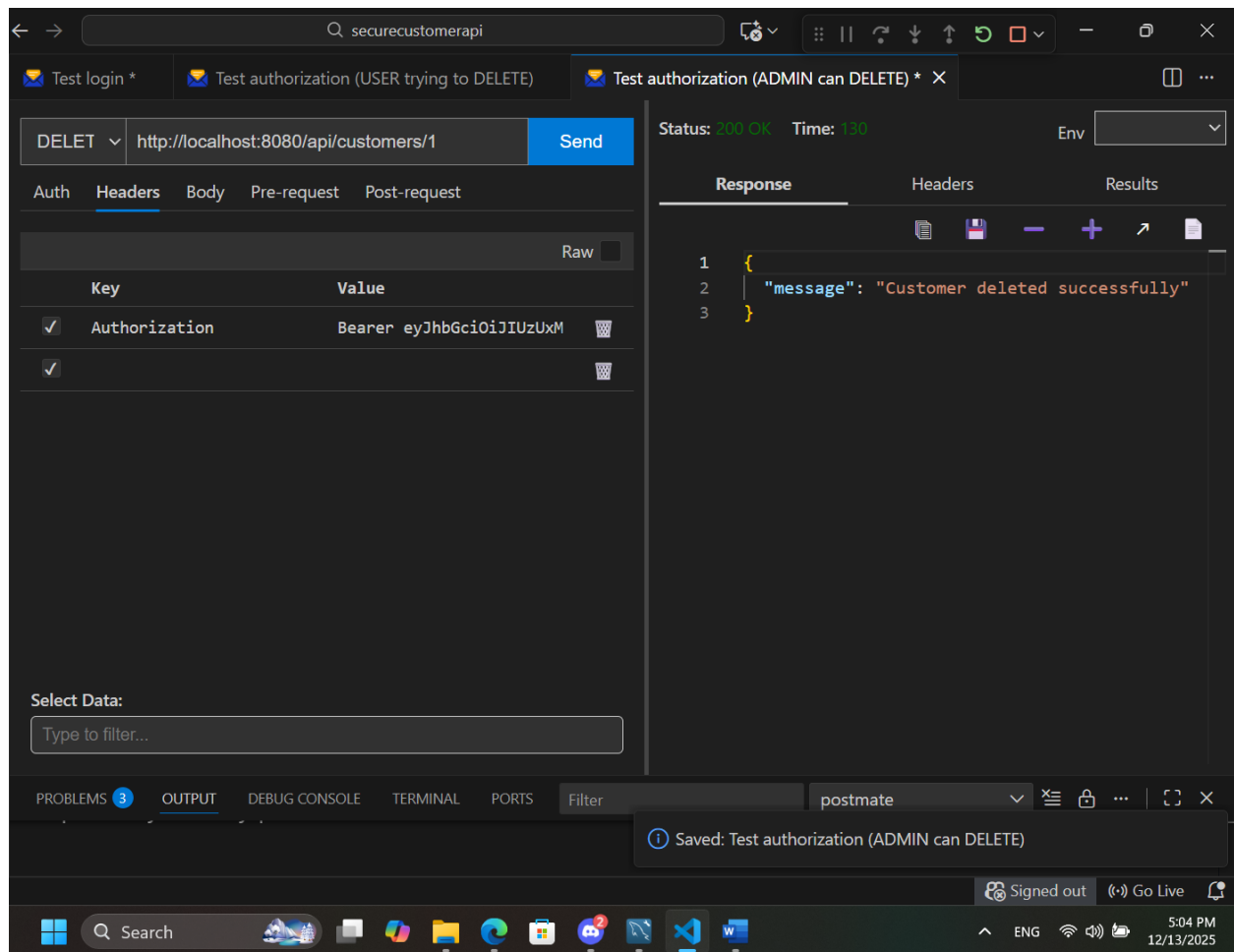


4. AUTHORIZATION CHECK

- Server → Check if user has required role (@PreAuthorize)
- If authorized → Process request
- If not authorized → Return 403 Forbidden
 - User



- Admin



5. LOGOUT

Client → POST /api/auth/logout

Client → Remove token from localStorage

Server → Return: {message: "Logged out"}